

# Informe Profesional de Pentesting

## Actividad A08 — Hacking Ético · Cliente: INSECUR S.A.

**Seguridad Aplicada a Sistemas de Información** Licenciatura en Sistemas de Información — Facultad de Informática y Diseño Docente: Ing. Rodrigo Atilio Elgueta Laboratorio: TryHackMe

### 6.1 Datos generales

| Campo                      | Valor                           |
|----------------------------|---------------------------------|
| Cliente                    | INSECUR S.A.                    |
| Contratista (alumno)       | Lautaro Barbero                 |
| DNI                        | 44820797                        |
| Username TryHackMe         | lautarobarbero                  |
| Email                      | lautarobarbero0107003@gmail.com |
| Sala de elección (Nivel 2) | Vulniversity                    |
| Branch en GitHub           | barbero-lautaro                 |
| Fecha de inicio            | 2026-10-06                      |
| Fecha de cierre            | 2026-10-07                      |

### 6.2 Pre-pentesting

#### Alcance del trabajo

El trabajo abarca **únicamente** los siguientes entornos de laboratorio de TryHackMe, asignados y autorizados por la cátedra:

- tryhackme.com/room/pentestingfundamentals (teórica — metodología)
- tryhackme.com/room/basicpentestingjt (máquina objetivo)
- tryhackme.com/room/vulniversity (máquina objetivo — sala de elección)

**Fuera de alcance:** cualquier sistema real, de producción, de la Facultad o de terceros, y cualquier dirección IP no provista por TryHackMe dentro de las salas indicadas. No se realizaron acciones de denegación de servicio, borrado o modificación destructiva de datos, ni persistencia más allá de lo necesario para evidenciar cada hallazgo.

#### Reglas de Enfrentamiento (ROE)

- Ventana de trabajo:** período de laboratorio del TP (06-07/10/2026). Las máquinas de THM tienen tiempo de vida limitado y se reinician al expirar.
- Técnicas prohibidas:** DoS/DDoS, borrado o cifrado de datos, ataques a la infraestructura de TryHackMe fuera de la IP objetivo asignada, pivoting hacia redes no autorizadas.
- Límites de tráfico:** escaneos acotados ( `nmap --min-rate` moderado) para no saturar el laboratorio compartido.
- Fuerza bruta:** limitada a 4 hilos ( `hydra -t 4` ) y solo sobre usuarios ya identificados, exclusivamente contra la IP autorizada.
- Notificación ante incidentes:** ante comportamiento anómalo del entorno, se detiene la actividad y se documenta; en un escenario real se notificaría de inmediato al punto de contacto del cliente.

#### Autorización

Se cuenta con **autorización expresa de la cátedra** (carta de autorización de la guía A08, Sección 1) para trabajar sobre los entornos de laboratorio de TryHackMe indicados en el alcance, en el marco del contrato de Hacking Ético con INSECUR S.A.

#### Metodología utilizada

Se adoptó el marco **PTES (Penetration Testing Execution Standard)**, por su correspondencia directa con el flujo de fases de la guía (pre-engagement → reconocimiento → escaneo → enumeración → explotación → post-explotación → reporte). Se complementó con la **OWASP Web Security Testing Guide (WSTG)** para la explotación web (Vulnversity) y con **NIST SP 800-115** para la estructura del testing técnico. El enfoque fue **black box**: se partió únicamente de la IP objetivo, sin información previa, enumerando toda la superficie de ataque.

### 6.3 Hallazgos por fase

Se documentan 12 hallazgos relevantes distribuidos en las dos máquinas comprometidas. Basic Pentesting: H-01 a H-07. Vulnversity: H-08 a H-12.

#### Hallazgo H-01 — Enumeración anónima de usuarios vía SMB

| Campo                        | Valor                                                                                                                                                    |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-01                                                                                                                                                     |
| Fase                         | <input checked="" type="checkbox"/> Enumeración                                                                                                          |
| Descripción                  | El servicio Samba permite enumerar las cuentas del sistema (RID cycling) sin autenticación, revelando los usuarios <code>kay</code> y <code>jan</code> . |
| Componente afectado          | Samba smbd 4 (puertos 139/445) — Basic Pentesting                                                                                                        |
| Categoría (OWASP / CWE)      | A05:2021 Security Misconfiguration / CWE-200                                                                                                             |
| CVE (si aplica)              | No aplica (configuración)                                                                                                                                |
| CVSS estimado                | <input checked="" type="checkbox"/> Medio                                                                                                                |
| Evidencia                    | evidencias/escaneo/escaneo_enum4linux_usuarios.png                                                                                                       |
| Herramienta utilizada        | enum4linux                                                                                                                                               |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad                                                                                                     |
| Salvaguarda propuesta        | Deshabilitar enumeración anónima/null sessions ( <code>restrict anonymous = 2</code> , <code>map to guest = Never</code> ); limitar exposición SMB.      |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                                                                 |

#### Hallazgo H-02 — Directory indexing habilitado

| Campo                        | Valor                                                                                                               |
|------------------------------|---------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-02                                                                                                                |
| Fase                         | <input checked="" type="checkbox"/> Enumeración                                                                     |
| Descripción                  | El directorio <code>/development/</code> lista su contenido (directory indexing), exponiendo archivos no enlazados. |
| Componente afectado          | Apache 2.4.41, ruta <code>/development/</code> — Basic Pentesting                                                   |
| Categoría (OWASP / CWE)      | A05:2021 Security Misconfiguration / CWE-548                                                                        |
| CVE (si aplica)              | No aplica                                                                                                           |
| CVSS estimado                | <input checked="" type="checkbox"/> Bajo                                                                            |
| Evidencia                    | evidencias/escaneo/escaneo_development_dir.png                                                                      |
| Herramienta utilizada        | nikto, gobuster, navegador                                                                                          |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad                                                                |
| Salvaguarda propuesta        | Deshabilitar <code>Options Indexes</code> en Apache; restringir acceso a directorios internos.                      |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                            |

#### Hallazgo H-03 — Divulgación de información en notas de desarrollo

|  |  |
|--|--|
|  |  |
|--|--|

| Campo                        | Valor                                                                                                                                                                |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-03                                                                                                                                                                 |
| Fase                         | <input checked="" type="checkbox"/> Enumeración                                                                                                                      |
| Descripción                  | Archivos <code>dev.txt</code> y <code>j.txt</code> exponen información interna de infraestructura y una admisión explícita de que un usuario tiene contraseña débil. |
| Componente afectado          | <code>/development/dev.txt</code> , <code>/development/j.txt</code> — Basic Pentesting                                                                               |
| Categoría (OWASP / CWE)      | A01:2021 Broken Access Control / CWE-200                                                                                                                             |
| CVE (si aplica)              | No aplica                                                                                                                                                            |
| CVSS estimado                | <input checked="" type="checkbox"/> Medio                                                                                                                            |
| Evidencia                    | <code>evidencias/escaneo/escaneo_devtxt.png</code> , <code>escaneo_jtxt.png</code>                                                                                   |
| Herramienta utilizada        | curl, navegador                                                                                                                                                      |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad                                                                                                                 |
| Salvaguarda propuesta        | No almacenar información sensible en rutas accesibles por la web; revisar contenido publicado; política de clasificación de información.                             |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                                                                             |

#### Hallazgo H-04 — Autenticación SSH débil (contraseña de diccionario)

| Campo                        | Valor                                                                                                                              |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-04                                                                                                                               |
| Fase                         | <input checked="" type="checkbox"/> Explotación                                                                                    |
| Descripción                  | La cuenta <code>jan</code> usa una contraseña trivial presente en <code>rockyou</code> , permitiendo acceso SSH por fuerza bruta.  |
| Componente afectado          | OpenSSH (puerto 22), usuario <code>jan</code> — Basic Pentesting                                                                   |
| Categoría (OWASP / CWE)      | A07:2021 Identification and Authentication Failures / CWE-521                                                                      |
| CVE (si aplica)              | No aplica                                                                                                                          |
| CVSS estimado                | <input checked="" type="checkbox"/> Alto                                                                                           |
| Evidencia                    | <code>evidencias/explotacion/explotacion_hydra_jan.png</code>                                                                      |
| Herramienta utilizada        | hydra                                                                                                                              |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad                                |
| Salvaguarda propuesta        | Política de contraseñas robustas; bloqueo tras intentos fallidos ( <code>fail2ban</code> ); MFA; preferir autenticación por clave. |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                                           |

#### Hallazgo H-05 — Clave privada SSH con permisos inseguros

| Campo                   | Valor                                                                                                                                                           |
|-------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo         | H-05                                                                                                                                                            |
| Fase                    | <input checked="" type="checkbox"/> Post-explotación                                                                                                            |
| Descripción             | La clave privada SSH de <code>kay</code> ( <code>/home/kay/.ssh/id_rsa</code> ) es legible por otros usuarios, permitiendo movimiento lateral / toma de cuenta. |
| Componente afectado     | Sistema de archivos, <code>/home/kay/.ssh/id_rsa</code> — Basic Pentesting                                                                                      |
| Categoría (OWASP / CWE) | A01:2021 Broken Access Control / CWE-732                                                                                                                        |
| CVE (si aplica)         | No aplica                                                                                                                                                       |
| CVSS estimado           | <input checked="" type="checkbox"/> Alto                                                                                                                        |

|                              |                                                                                                     |
|------------------------------|-----------------------------------------------------------------------------------------------------|
| Evidencia                    | evidencias/post/post_ssh_key_kay.png                                                                |
| Herramienta utilizada        | ssh, scp                                                                                            |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad |
| Salvaguarda propuesta        | Permisos 600 en claves privadas; auditoría de permisos; no dejar claves en ubicaciones accesibles.  |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                            |

### Hallazgo H-06 — Passphrase de clave SSH débil

| Campo                        | Valor                                                                                                |
|------------------------------|------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-06                                                                                                 |
| Fase                         | <input checked="" type="checkbox"/> Post-explotación                                                 |
| Descripción                  | La passphrase que protege la clave privada de kay es débil y se crackea con diccionario en segundos. |
| Componente afectado          | Clave privada de kay — Basic Pentesting                                                              |
| Categoría (OWASP / CWE)      | A02:2021 Cryptographic Failures / CWE-521, CWE-326                                                   |
| CVE (si aplica)              | No aplica                                                                                            |
| CVSS estimado                | <input checked="" type="checkbox"/> Medio                                                            |
| Evidencia                    | evidencias/explotacion/explotacion_john_kay.png                                                      |
| Herramienta utilizada        | ssh2john, john                                                                                       |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad                                                 |
| Salvaguarda propuesta        | Passphrases robustas en claves; rotación de claves comprometidas.                                    |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                             |

### Hallazgo H-07 — Escalada a root vía sudo sin restricciones

| Campo                        | Valor                                                                                                                                                  |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-07                                                                                                                                                   |
| Fase                         | <input checked="" type="checkbox"/> Post-explotación                                                                                                   |
| Descripción                  | El usuario kay puede ejecutar (ALL : ALL) ALL con sudo, permitiendo convertirse en root y comprometer totalmente el sistema.                           |
| Componente afectado          | Configuración de sudoers, usuario kay — Basic Pentesting                                                                                               |
| Categoría (OWASP / CWE)      | A01:2021 Broken Access Control / CWE-269, CWE-250                                                                                                      |
| CVE (si aplica)              | No aplica                                                                                                                                              |
| CVSS estimado                | <input checked="" type="checkbox"/> Crítico                                                                                                            |
| Evidencia                    | evidencias/post/post_acceso_kay_y_post_root.png                                                                                                        |
| Herramienta utilizada        | sudo                                                                                                                                                   |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad |
| Salvaguarda propuesta        | Principio de menor privilegio en sudoers; restringir comandos; requerir contraseña fuerte; auditar accesos privilegiados.                              |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                                                               |

### Hallazgo H-08 — Componentes web desactualizados

| Campo           | Valor                                       |
|-----------------|---------------------------------------------|
| ID del hallazgo | H-08                                        |
| Fase            | <input checked="" type="checkbox"/> Escaneo |

|                              |                                                                                                                                    |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| Descripción                  | El servidor web corre en puerto no estándar (3333) con Apache 2.4.41 desactualizado respecto a versiones con parches de seguridad. |
| Componente afectado          | Apache 2.4.41 (puerto 3333) — Vulniversity                                                                                         |
| Categoría (OWASP / CWE)      | A06:2021 Vulnerable and Outdated Components / CWE-1104                                                                             |
| CVE (si aplica)              | Varios asociados a versiones antiguas de Apache                                                                                    |
| CVSS estimado                | <input checked="" type="checkbox"/> Bajo                                                                                           |
| Evidencia                    | evidencias/escaneo/escaneo_nmap_vulniversity.png                                                                                   |
| Herramienta utilizada        | nmap                                                                                                                               |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad                                  |
| Salvaguarda propuesta        | Gestión de parches; actualizar Apache; endurecer configuración; no exponer servicios en puertos innecesarios.                      |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                                           |

### Hallazgo H-09 — Directorio interno sin autenticación

| Campo                        | Valor                                                                                                                 |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-09                                                                                                                  |
| Fase                         | <input checked="" type="checkbox"/> Enumeración                                                                       |
| Descripción                  | El directorio <code>/internal/</code> expone un formulario de subida de archivos sin ningún control de autenticación. |
| Componente afectado          | <code>http://&lt;IP&gt;:3333/internal/</code> — Vulniversity                                                          |
| Categoría (OWASP / CWE)      | A01:2021 Broken Access Control / CWE-306                                                                              |
| CVE (si aplica)              | No aplica                                                                                                             |
| CVSS estimado                | <input checked="" type="checkbox"/> Medio                                                                             |
| Evidencia                    | evidencias/escaneo/escaneo_internal_upload.png                                                                        |
| Herramienta utilizada        | gobuster, navegador                                                                                                   |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad                   |
| Salvaguarda propuesta        | Requerir autenticación y autorización para funciones sensibles; segmentar zonas internas.                             |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                              |

### Hallazgo H-10 — Carga de archivos insegura (bypass de filtro)

| Campo                    | Valor                                                                                                                                                  |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo          | H-10                                                                                                                                                   |
| Fase                     | <input checked="" type="checkbox"/> Explotación                                                                                                        |
| Descripción              | El filtro de subida usa una lista negra incompleta: bloquea <code>.php</code> pero permite <code>.phtml</code> , que Apache ejecuta como PHP.          |
| Componente afectado      | <code>/internal/index.php</code> (handler de subida) — Vulniversity                                                                                    |
| Categoría (OWASP / CWE)  | A04:2021 Insecure Design / CWE-434                                                                                                                     |
| CVE (si aplica)          | No aplica                                                                                                                                              |
| CVSS estimado            | <input checked="" type="checkbox"/> Crítico                                                                                                            |
| Evidencia                | evidencias/explotacion/explotacion_fuzz_extension.png                                                                                                  |
| Herramienta utilizada    | curl (fuzzing de extensiones); equivalente a Burp Suite Intruder                                                                                       |
| Impacto en la Tríada CIA | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad |
| Salvaguarda propuesta    | Validación por lista blanca de extensiones y tipo MIME;                                                                                                |

|                              |                                                                                                         |
|------------------------------|---------------------------------------------------------------------------------------------------------|
|                              | renombrar archivos; almacenar fuera de la raíz web; deshabilitar ejecución en el directorio de subidas. |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                |

### Hallazgo H-11 — Ejecución remota de código (RCE)

| Campo                        | Valor                                                                                                                                                          |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-11                                                                                                                                                           |
| Fase                         | <input checked="" type="checkbox"/> Explotación                                                                                                                |
| Descripción                  | La subida de un <code>.phtml</code> con una reverse shell permite ejecutar código arbitrario en el servidor, obteniendo una shell como <code>www-data</code> . |
| Componente afectado          | Servidor web Apache / PHP — Vulniversity                                                                                                                       |
| Categoría (OWASP / CWE)      | A03:2021 Injection / CWE-94                                                                                                                                    |
| CVE (si aplica)              | No aplica (derivado de H-10)                                                                                                                                   |
| CVSS estimado                | <input checked="" type="checkbox"/> Crítico                                                                                                                    |
| Evidencia                    | evidencias/explotacion/explotacion_shell_wwwdata.png                                                                                                           |
| Herramienta utilizada        | php-reverse-shell (pentestmonkey), netcat                                                                                                                      |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad         |
| Salvaguarda propuesta        | Corregir H-10; WAF; ejecución del servidor web con mínimos privilegios; monitoreo de conexiones salientes.                                                     |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                                                                       |

### Hallazgo H-12 — Escalada a root vía SUID en systemctl

| Campo                        | Valor                                                                                                                                                                |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo              | H-12                                                                                                                                                                 |
| Fase                         | <input checked="" type="checkbox"/> Post-explotación                                                                                                                 |
| Descripción                  | El binario <code>/bin/systemctl</code> tiene el bit SUID, permitiendo crear y ejecutar un servicio como root (técnica GTFOBins) y comprometer totalmente el sistema. |
| Componente afectado          | <code>/bin/systemctl</code> (bit SUID) — Vulniversity                                                                                                                |
| Categoría (OWASP / CWE)      | A05:2021 Security Misconfiguration / CWE-269, CWE-732                                                                                                                |
| CVE (si aplica)              | No aplica (configuración)                                                                                                                                            |
| CVSS estimado                | <input checked="" type="checkbox"/> Crítico                                                                                                                          |
| Evidencia                    | evidencias/post/post_suid.png ,<br>evidencias/post/post_root.png                                                                                                     |
| Herramienta utilizada        | find, systemctl (GTFOBins)                                                                                                                                           |
| Impacto en la Tríada CIA     | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad               |
| Salvaguarda propuesta        | Eliminar el bit SUID de binarios que no lo requieren ( <code>chmod u-s /bin/systemctl</code> ); auditoría periódica de binarios SUID; principio de menor privilegio. |
| Riesgo residual tras aplicar | <input checked="" type="checkbox"/> Bajo                                                                                                                             |

## 6.4 Resumen ejecutivo de hallazgos

| Severidad | Cantidad | ID de hallazgos        |
|-----------|----------|------------------------|
| Crítico   | 4        | H-07, H-10, H-11, H-12 |
| Alto      | 2        | H-04, H-05             |

|              |           |                        |
|--------------|-----------|------------------------|
| Medio        | 4         | H-01, H-03, H-06, H-09 |
| Bajo         | 2         | H-02, H-08             |
| <b>Total</b> | <b>12</b> |                        |

**Conclusión ejecutiva:** ambas máquinas fueron **comprometidas totalmente** (acceso root). En los dos casos, la causa raíz no fue una única vulnerabilidad crítica aislada, sino una **cadena de debilidades encadenadas** — configuración insegura, credenciales y permisos débiles, y validación deficiente de entradas — que, combinadas, permitieron pasar de un acceso nulo a control total del sistema. Esto refuerza la necesidad de aplicar defensa en profundidad y el principio de menor privilegio en todas las capas.

## 6.5 Post-pentesting: Recomendaciones

### Recomendaciones técnicas (parches y configuraciones)

1. **Corregir la carga de archivos (crítico):** validación por lista blanca de extensiones y tipo MIME, almacenamiento fuera de la raíz web y sin permisos de ejecución (H-10, H-11).
2. **Remover bits SUID innecesarios:** `chmod u-s /bin/systemctl` y auditoría de todos los binarios SUID (H-12).
3. **Endurecer sudo:** aplicar menor privilegio en `/etc/sudoers`, evitar `(ALL) ALL` (H-07).
4. **Política de contraseñas y claves:** contraseñas y passphrases robustas, MFA, bloqueo por intentos fallidos (`fail2ban`), permisos `600` en claves privadas (H-04, H-05, H-06).
5. **Reducir exposición y divulgación:** deshabilitar directory indexing y enumeración SMB anónima; quitar notas internas de rutas web (H-01, H-02, H-03, H-09).
6. **Gestión de parches:** actualizar Apache y el resto de componentes; cerrar puertos/servicios innecesarios (H-08).

### Recomendaciones administrativas (políticas y procesos)

1. Política formal de contraseñas y gestión de credenciales.
2. Programa de gestión de parches con ventana periódica.
3. Revisiones de configuración (hardening) y auditorías de permisos recurrentes.
4. Capacitación en desarrollo seguro (validación de entradas, manejo de archivos).
5. Clasificación de la información y control de qué se publica en servidores web.
6. Pruebas de seguridad periódicas (pentesting) como parte del ciclo de vida.

## PARTE III — Protocolo de Contingencia

### Escenario de falla

La explotación de la carga insegura de archivos (H-10/H-11) implica subir y ejecutar código en el servidor web. En un entorno de producción, un payload mal construido o una reverse shell que consuma recursos podría **degradar o tumbar el servicio web** (proceso Apache/PHP), o dejar artefactos (archivos subidos, servicios systemd creados en H-12) que afecten la estabilidad del sistema.

### Impacto sobre la continuidad del negocio

Una caída del servidor web de INSECUR S.A. interrumpiría los servicios en línea de cara al cliente (portal, formularios, operatoria web). Según la criticidad del servicio, el impacto podría ir desde minutos de indisponibilidad hasta la pérdida de confianza y datos si el atacante tuviera intención destructiva. El compromiso root (H-07/H-12) implicaría además riesgo sobre **toda** la información alojada.

### Plan de respuesta

1. **Activación:** detección por monitoreo (caída de servicio, conexiones salientes anómalas, archivos nuevos en directorios web, servicios systemd no autorizados / alertas de IDS).
2. **Contención (primeros 15 min):** aislar el host de la red, cortar conexiones salientes sospechosas, deshabilitar el formulario de subida afectado, preservar evidencia (no apagar en caliente si se requiere análisis forense).
3. **Recuperación:** restaurar desde backup limpio o servidor espejo; aplicar los parches de H-10/H-12 antes de reconectar; rotar credenciales y claves potencialmente comprometidas.
4. **Comunicación:** notificar a dirección/IT, y —según normativa y datos afectados— a clientes y autoridades correspondientes.

5. **Post-mortem:** documentar causa raíz, línea de tiempo y lecciones aprendidas; actualizar controles y procedimientos. (En este ejercicio, el servicio `systemd` creado para la escalada se eliminaría como parte de la limpieza — buena práctica de cierre de un pentest.)

### RTO y RPO estimados

- **RTO** (Recovery Time Objective):  $\leq 4$  horas (restauración desde backup/espejo y aplicación de parches críticos).
- **RPO** (Recovery Point Objective):  $\leq 24$  horas (último backup diario).

## Anexos

### Anexo A — Bitácora de comandos

Archivos en `bitacora/`: - `sala1_pentesting_fundamentals.md`, `sala2_basic_pentesting.md`, `sala3_vulniversity.md` - Salidas de herramientas: `nmap_*.txt`, `enum4linux_basic.txt`, `gobuster_*.txt`, `nikto_basic.txt`, `hydra_jan.txt` (secretos redactados).

### Anexo B — Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por fase (`reconocimiento/`, `escaneo/`, `explotacion/`, `post/`). Nomenclatura `<fase>_<descripción>.png`. Cada captura crítica muestra el username de THM (`lautarobarbero`) o el reloj del sistema + la IP objetivo, según corresponda.

### Anexo C — Hashes de las flags / secretos obtenidos

En lugar de los valores en texto plano, se incluye el hash SHA-256 de cada uno. Generación: `echo -n "<valor>" | sha256sum`

```
# Basic Pentesting
jan:password      9eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617
kay:ssh_passphrase 873504f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08
kay:pass.bak      3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57

# Vulniversity
user.txt          d324bd433001e5bdfc39e04d794539c15b51982a5bf6fc78efea46369b7bf956
root.txt          cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
```

### Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados (sandbox) de TryHackMe y con fines exclusivamente académicos.

Firma del estudiante: \_\_\_\_\_ Fecha: 2026-10-07

### Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals* — <https://tryhackme.com/room/pentestingfundamentals>
- TryHackMe. *Basic Pentesting* — <https://tryhackme.com/room/basicpentestingit>
- TryHackMe. *Vulniversity* — <https://tryhackme.com/room/vulniversity>
- OWASP Foundation. *Web Security Testing Guide (WSTG)* y *OWASP Top 10 (2021)*.
- GTF0Bins — <https://gtfobins.github.io/> (técnica de escalada vía SUID `systemctl`).
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.ª ed.). IC Editorial.